

лекция 15.

Технологии обнаружения и предотвращения вторжений



Учебные вопросы:

1. Системы обнаружения вторжений (IDS)
2. Классификация IDS
3. Архитектура IDS
4. Сигнатурный анализ и обнаружение аномалий
5. Обнаружение атак в реальном времени и отложенный анализ
6. Локальные и сетевые системы обнаружения атак
7. Распределенные системы обнаружения атак
8. Система предотвращения вторжений (IPS)

Дополнительный материал:



1) Системы обнаружения вторжений

Система обнаружения вторжений (IDS) — это программные или аппаратные решения, автоматизирующие мониторинг и анализ событий в компьютерных системах или сетях для выявления угроз безопасности. С ростом числа сетевых атак IDS стали важным элементом инфраструктуры.

Первые IDS появились в 1980-х годах и защищали автономные ЭВМ, анализируя журналы событий.

Современные системы ориентированы на защиту от сетевых угроз и имеют измененную архитектуру, но основные подходы к обнаружению атак остались прежними.

Обнаружение проникновений — это процесс мониторинга и анализа событий на предмет попыток компрометации конфиденциальности, целостности, доступности или обхода механизмов безопасности.

Проникновения могут быть совершены как внешними атакующими, так и внутренними пользователями, пытающимися получить дополнительные привилегии.

IDS автоматизируют мониторинг и анализ событий, используя три компонента: источники информации, анализ и ответ. Они обрабатывают данные из различных источников, анализируют их и реагируют на угрозы, создавая отчеты или принимая активные меры.



Характеристики систем обнаружения вторжений



Классификация систем обнаружения вторжений

2) Классификация IDS

Метод обнаружения описывает функции анализатора: поведенческие IDS используют информацию о нормальном поведении системы, интеллектуальные – о атаках.

Поведение после обнаружения определяет реакцию IDS: активная (корректирующие или ограничивающие действия) или пассивная (только предупреждения).

Расположение источников аудита подразделяет IDS по типу анализируемых данных: результаты аудита, системные журналы или сетевые пакеты.

Частота использования отражает непрерывный мониторинг или периодические запуски IDS для анализа.

По способам реагирования IDS делятся на статические и динамические.

Статические IDS анализируют «снимки» среды, выявляя уязвимости, ошибки в конфигурациях и следы вторжений. Динамические IDS мониторят действия в реальном времени, анализируя файлы аудита и сетевые пакеты.

По способу сбора информации IDS бывают сетевыми (NIDS) и системными.

NIDS контролируют сетевой трафик, обнаруживая попытки проникновения или атаки «отказ в обслуживании». Они могут работать на отдельном компьютере или прозрачно просматривать весь трафик в сети. Системные IDS, или хостовые, устанавливаются на хосте и обнаруживают злонамеренные действия внутри системы.

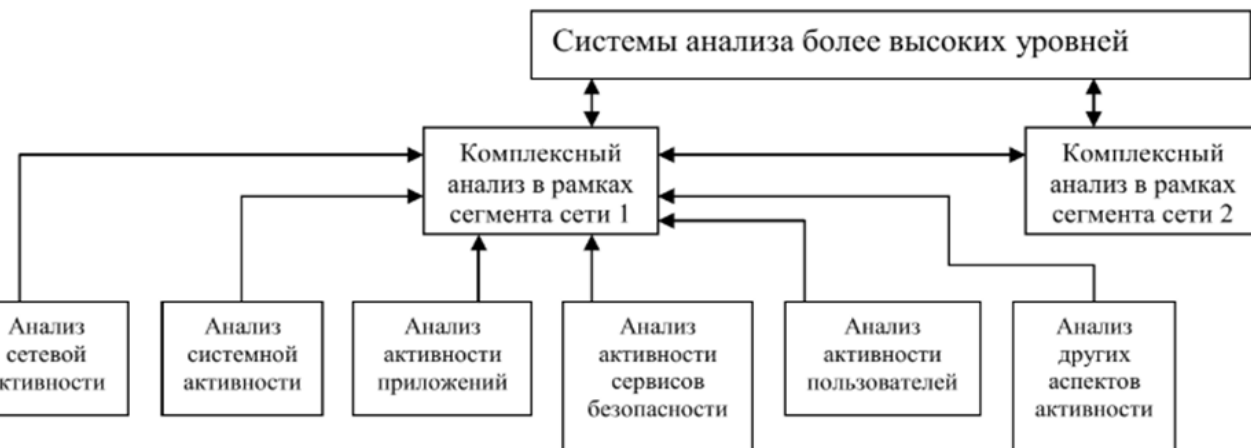
группы:

1. Анализ сигнатур: сравнивает информацию с базой известных атак. Если найденное совпадение соответствует сигнатуре, объявляется тревога. Эти системы быстрые и точные, но не могут выявлять новые атаки.
2. Анализ протоколов: проверяет соответствие полей протоколов ожидаемым значениям. Нарушения протокола указывают на злонамеренность. Такие системы могут быть медленными при большом количестве сигнатур.

3) Архитектура IDS



Основные элементы локальной архитектуры систем обнаружения вторжений.



Архитектура IDS включает функциональные компоненты и их взаимодействие. Основные компоненты: Host — система с ПО IDS, и Target — система под наблюдением.

Локальная архитектура:

- * Первичный сбор данных сенсорами.
- * Фильтрация данных на уровне сенсоров.
- * Передача данных в центр распределения для унификации и фильтрации.
- * Сохранение данных в базе и анализ статистическим и экспертным компонентами.
- * Решатель оценивает подозрительную активность и выбирает реакцию.
- * Система должна четко объяснять причины тревоги и предлагать действия.

Глобальная архитектура:

- * Одноранговые и разноранговые связи между локальными системами.
- * Анализ активности с разных точек зрения (пользователи, приложения, сеть).
- * Обобщение результатов для выявления скоординированных атак и оценки ущерба.

Глобальная архитектура систем обнаружения вторжений

Анализ событий в IDS

IDS используют два основных подхода: определение злоупотреблений (misuse detection) и аномалий (anomaly detection).

Определение злоупотреблений

Анализирует события на соответствие заранее известным шаблонам атак (сигнатурам).

Преимущества:

- * Эффективное выявление известных атак.
- * Быстрая диагностика инструментов атаки.
- * Доступность для администраторов любого уровня.

Недостатки:

- * Не распознает неизвестные атаки (Выявляет отклонения от нормального поведения на основе исторических данных)

Технологии:

- * Порог: количественные показатели.
- * Статистические метрики: параметрические и непараметрические.
- * Правила: спецификации на основе наблюдаемых данных.

Преимущества:

- * Обнаружение новых атак.
- * Использование данных для сигнатур злоупотреблений.

Недостатки:

- * Много ложных сигналов.
- * Требуется обучения.

Использует криптографические контрольные суммы (дайджесты) для выявления изменений в системных файлах.

Преимущества:

- * Обнаружение атак, лазеек и исправлений.
- * Поддержка восстановления после инцидентов.

Заключение

IDS с сигнатурным подходом эффективны для известных атак, но ограничены. IDS на основе аномалий могут выявлять новые угрозы, но создают ложные сигналы. Проверка целостности файлов помогает контролировать целостность системы и упрощает восстановление после атак.

4) Сигнатурный анализ или обнаружения аномалий

Обнаружение атак основано на сигнатурном анализе или обнаружении аномалий, либо их комбинации. Сигнатурный анализ выявляет известные сценарии атак через анализ журналов событий или сетевого трафика. Администратор должен устранять уязвимости, но это может снизить функциональность или оказаться экономически нецелесообразным. Системы сигнатурного анализа ищут заранее известные последовательности событий или строк в потоке информации. Описание атаки может быть на основе правил или конечных автоматов, что позволяет учитывать динамику развития атаки. Недостатки сигнатурного анализа — невозможность обнаружения новых атак, если их сигнатуры отсутствуют в базе данных.

Подход на основе аномалий предполагает, что атака выводит систему из равновесного состояния. Для этого необходимо описать состояние системы, составить ее профиль и выбрать методы обнаружения аномалий. Преимущество этого подхода — возможность выявления новых атак, но он также имеет высокую вероятность ложных срабатываний и сложен в настройке. На рынке мало полноценных коммерческих продуктов, использующих этот метод, хотя разработки продолжаются.

5) Обнаружение атак в реальном времени и отложенный анализ

Системы обнаружения атак (СОА) делятся на «реального времени» и «отложенной обработки». Первые анализируют входящий поток событий от датчиков, вторые — журналы или записанный трафик. Реальные системы быстрее реагируют на атаки, но их эффективность зависит от простоты алгоритмов. Отложенные системы эффективнее для анализа инцидентов, выявления уязвимостей и минимизации требований. Основная цель СОА реального времени — быстрое реагирование и пресечение атак, часто через анализ заголовков пакетов на сетевом и транспортном уровнях OSI, что сокращает количество обнаруживаемых угроз.

6) Локальные и сетевые системы обнаружения атак (СОА)

Локальные СОА анализируют данные с одного компьютера, а сетевые — весь сетевой трафик.

Локальные СОА:

- * Отслеживают TCP- и UDP-соединения, выявляя несанкционированные подключения и сканирование портов.
- * Анализируют сетевой трафик на подозрительные пакеты.
- * Контролируют попытки регистрации, ограничивая время или разрешая вход только с определенных адресов.
- * Следят за активностью пользователей с повышенными полномочиями.
- * Проверяют целостность файлов и ключей реестра.

Сетевые СОА:

- * Анализируют сетевые пакеты, выявляя подозрительное содержимое и несанкционированные потоки.
- * Устанавливаются на маршрутизаторах или коммутаторах для максимального охвата трафика.
- * Эффективно обнаруживают сканирование портов и атаки «отказ в обслуживании».
- * Защищают локальные сети от внешних угроз через фильтрацию пакетов.

Сетевые СОА требуют значительных вычислительных ресурсов, особенно для крупных сетей.

7. Распределенные системы обнаружения атак (СОА)

Распределенные СОА перераспределяют функции сбора данных между агентами на узлах сети. Они могут анализировать информацию с компьютеров или данные, передаваемые по сети. Основной задачей является организация информационного обмена между агентами для принятия решения о факте атаки.

Преимущества: сбор и анализ большого объема данных для обнаружения широкого спектра атак. Эффективнее всего объединение локальных и сетевых СОА.

Недостатки: меньшая защищенность компонентов. Сбор данных с нескольких узлов нагружает сеть, что может привести к перегрузке при атаке. Открытые порты уязвимы для атак на отказ в обслуживании. Вредоносное ПО может блокировать агентов или подделывать данные.

При проектировании распределенных СОА важно выбрать процедуру принятия решения. Централизованная модель передает данные центральному узлу для анализа, но создает риски обнаружения и перегрузки сети. В больших сетях требуется многоступенчатый подход с промежуточными модулями для снижения нагрузки.

Первоочередной задачей остается обеспечение защищенности самой СОА.

8) Система предотвращения вторжений (IPS)

IPS — это программно-аппаратные средства для обнаружения и предотвращения несанкционированного доступа к компьютерным системам, особенно через Интернет или локальную сеть. Они выявляют аномальные действия, такие как атаки хакеров, инсайдеров или вредоносных программ, и блокируют их.

Основные цели IPS:

- * Обнаружение и предотвращение атак;
- * Прогнозирование будущих угроз;
- * Документирование инцидентов;
- * Контроль безопасности в сетях;
- * Сбор информации для восстановления после атак.

Классификация IPS:

1. NIPS (Network IPS) — для сетевого уровня и корпоративного сектора.
2. HIPS (Host IPS) — для отдельных компьютеров, часто входят в состав антивирусов.

Методы реагирования на атаки:

1. После начала атаки:

- * Блокирование соединения (TCP-пакеты RST).
- * Блокирование записей пользователей.
- * Блокирование хоста или сетевых интерфейсов.
- * Использование межсетевого экрана (МЭ) для фильтрации трафика.
- * Изменение конфигурации оборудования (SNMP, TFTP).
- * Активное подавление источника атаки (при определённых условиях).

2. В начале атаки:

- * Анализ пакетов с помощью сетевых или хостовых датчиков.
- * Перехват и анализ системных вызовов приложений.

Защита реализуется с помощью сигнатурного или поведенческого анализа.

